

FUTURE INTERNS — CYBER SECURITY TASK 2

Phishing Email Detection & Awareness System

A Complete Security Analyst Report

Prepared By
Atul |

Date
June 2026

Internship
Future Interns — CS Task 2

Version
v1.0 — Final Submission

Executive Summary

This report presents a complete phishing email detection and awareness analysis conducted as part of Future Interns Cyber Security Task 2. Three real-world phishing email samples are analyzed for indicators of compromise, classified by risk level, and explained in business-friendly language. The report concludes with prevention guidelines and Do's & Don'ts for employees.

1. Introduction to Phishing

Phishing is a cyberattack where criminals impersonate trusted organizations to steal credentials, install malware, or commit financial fraud. It is the most common initial attack vector in data breaches worldwide.

Why Phishing is Dangerous

- Over 3.4 billion phishing emails are sent every day worldwide
- 91% of all cyberattacks begin with a phishing email
- Average financial loss per phishing incident: \$136,000 for mid-sized organizations
- Most attacks succeed because of user unawareness — not weak technology

1.1 Types of Phishing Attacks

Type	Description	Target
Email Phishing	Mass emails impersonating trusted brands	General public, employees
Spear Phishing	Targeted attack using victim's personal data	Executives, HR, Finance
Whaling	Attacks targeting C-suite executives specifically	CEO, CFO, Board
Smishing	Phishing via SMS text messages	Mobile users
Vishing	Voice call impersonation of support teams	Elderly, remote workers
Clone Phishing	Duplicates real emails with malicious links	Email users
Business Email Compromise	Impersonates executives to approve fraud	Finance departments

2. Phishing Email Samples & Analysis

Four phishing email samples are analyzed below. The first three include a simulated email display, full indicator analysis, how the attack works, and risk classification. The fourth is a header-only forensic analysis using a real authentication-result trace.

Sample 1 — Amazon Account Verification Scam

PHISHING EMAIL SAMPLE

From: Amazon Security Team <security-alert@amazon-support-center.com>
Reply-To: support@amazon-support-center.com

Subject: Important: Verify Your Amazon Account

Hello Customer,

We detected unusual activity on your Amazon account from a new device located in an unknown location. To keep your account safe, we have temporarily locked access to your account.

To restore full access, please verify your identity by clicking the button below and following the instructions.

>>> VERIFY MY ACCOUNT <<<

This link will expire in 24 hours.

Failure to verify may result in permanent account suspension.

Indicator Analysis — Sample 1

#	Phishing Indicator	Evidence Found	Severity
1	Fake Sender Domain	amazon-support-center.com — real Amazon uses @amazon.com only	HIGH
2	Generic Greeting	"Hello Customer" — not your real name, mass-sent email	HIGH
3	Urgency Language	"locked access", "24 hours", "immediately"	HIGH
4	Fear Tactic	"permanent account suspension" — psychological pressure	HIGH
5	Hidden Malicious URL	"Verify My Account" button hides phishing link	HIGH
6	Gmail EXTERNAL Flag	Gmail itself flagged this as EXTERNAL — not from Amazon servers	HIGH
7	Fake Trust Badges	Secure / Protect / Support icons — visual deception	MEDIUM
8	Copied Branding	Amazon logo stolen to appear legitimate	MEDIUM

How This Attack Works

The attacker registered amazon-support-center.com — a lookalike domain — and copied Amazon's branding including logo, colors, and layout. The email creates panic ("account locked") and urgency ("24 hours") to make the victim click the "Verify My Account" button without thinking. The button leads to a fake Amazon login page that captures the victim's email and password, which the attacker then uses to access the real Amazon account.

RISK CLASSIFICATION: PHISHING — HIGH RISK | Credential Harvesting

Sample 2 — Bank OTP / Credential Theft

PHISHING EMAIL SAMPLE

From: SBI Security Team <alert@sbi-secure-banking.net>
Reply-To: noreply@sbi-alert-center.org
Subject: URGENT: Your SBI Account Has Been Temporarily Suspended

Dear Valued Customer,

We have detected multiple failed login attempts on your SBI Net Banking account. For your security, your account has been temporarily suspended.

To reactivate your account, please click the link below and enter your:

- Net Banking User ID & Password
- Registered Mobile Number
- OTP sent to your mobile

Reactivate Now: [http://sbi-secure-banking\[.\]net/verify](http://sbi-secure-banking[.]net/verify)

Ignore this email at your own risk. Unresolved cases lead to permanent account closure.

Indicator Analysis — Sample 2

#	Phishing Indicator	Evidence Found	Severity
1	Fake Bank Domain	sbi-secure-banking.net — SBI only uses @sbi.co.in	CRITICAL
2	Requests OTP Directly	No bank ever asks for OTP via email — this is the attack goal	CRITICAL
3	Requests Password	Asking for Net Banking password — banks never do this	CRITICAL
4	HTTP Link (No HTTPS)	http:// not https:// — no SSL security	HIGH
5	Mismatched Domains	From: sbi-secure-banking.net, Reply-To: sbi-alert-center.org	HIGH
6	Threatening Language	"at your own risk", "permanent account closure"	HIGH
7	Generic Greeting	"Dear Valued Customer" — not a personalized bank email	MEDIUM

How This Attack Works

This is a multi-credential harvesting attack. The attacker creates a fake SBI banking portal that requests User ID, password, phone number, and OTP simultaneously — giving them everything needed for a complete account takeover. When the victim enters the OTP, the attacker uses it in real time on the actual SBI website to authorize a fraudulent transaction before the OTP expires.

RISK CLASSIFICATION: PHISHING — CRITICAL RISK | Banking Fraud / OTP Interception

Sample 3 — IT Helpdesk / Password Reset Impersonation

PHISHING EMAIL SAMPLE

From: IT Helpdesk <it-support@company-it-helpdesk.org>
 Reply-To: admin@company-it-helpdesk.org
Subject: [IT SUPPORT] Mandatory Password Reset — Action Required Within 2 Hours

Dear Employee,

Our security systems have detected unauthorized access attempts on your corporate account. As a mandatory security measure, you are required to reset your password immediately.

Reset your password here:

[https://company-it-helpdesk\[.\]org/reset?user=employee](https://company-it-helpdesk[.]org/reset?user=employee)

You have 2 hours to complete this action. Failure to comply will result in your account being permanently disabled and you will be unable to access company systems.

Do NOT share your new password with anyone, including IT staff.

IT Security Team Company IT Division

Indicator Analysis — Sample 3

#	Phishing Indicator	Evidence Found	Severity
1	External Lookalike Domain	company-it-helpdesk.org — IT teams use internal corporate domains	HIGH
2	IT Authority Impersonation	Impersonates internal IT to bypass employee skepticism	HIGH
3	Extreme Time Pressure	"2 hours" — artificially short window to force panic	HIGH
4	URL Tracking Parameter	?user=employee — confirms to attacker which employee clicked	MEDIUM
5	Account Termination Threat	"permanently disabled" — escalated fear tactic	HIGH
6	False Security Warning	"Do NOT share password with IT" — fake trust signal	LOW
7	Unsolicited Reset Request	Real IT resets are user-initiated, not email-pushed	HIGH

How This Attack Works

The attacker impersonates an internal IT department to harvest Active Directory (AD) or corporate SSO credentials. The fake password reset page captures the employee's current password. With corporate credentials, the attacker can access email, internal systems, VPN, and cloud services — often leading to lateral movement across the entire organization.

RISK CLASSIFICATION: PHISHING — HIGH RISK | Corporate Credential Theft

Sample 4 — Wells Fargo Domain Spoofing (Header-Based Detection)

Unlike the previous samples, this attack is detected purely through email header analysis using the Google Admin Toolbox Messageheader tool — no visual email design was needed to confirm this is phishing.

RAW EMAIL HEADERS — SAMPLE 4

```
Received: from attacker-server.com (192.0.2.145)
  by mail-protection-outlook.com; Wed, 10 Jun 2026 10:35:12 -0500
From: "Customer Support" <support@wellsfargo.com>
Reply-To: <update-services@fastmail.com>
Return-Path: <bounce@attacker-server.com>
Subject: Security Alert: Your account has been suspended
X-Mailer: PHPMailer 5.2 (phpmailer.sourceforge.net)
Authentication-Results: spf=fail (sender IP is 192.0.2.145)
smtp.mailfrom=attacker-server.com; dkim=none; dmarc=none
```

Indicator Analysis — Sample 4

#	Phishing Indicator	Evidence Found	Severity
1	Display Name Spoofing	"Customer Support" <support@wellsfargo.com> — fake sender identity	CRITICAL
2	Sending Server Mismatch	Received: from attacker-server.com (192.0.2.145) — not Wells Fargo infrastructure	CRITICAL
3	SPF Authentication FAIL	spf=fail — sender IP 192.0.2.145 not authorized by wells Fargo.com	CRITICAL
4	DKIM Missing	dkim=none — no cryptographic proof of authenticity	HIGH
5	DMARC Missing	dmarc=none — no enforcement policy applied	HIGH
6	Reply-To Mismatch	update-services@fastmail.com — unrelated third- party domain	HIGH
7	Return-Path Mismatch	bounce@attacker-server.com — bounces routed to attacker	HIGH
8	Bulk Mailer Signature	X-Mailer: PHPMailer 5.2 — scripted bulk-mail tool, not enterprise mail system	MEDIUM
9	Fear-Based Subject Line	"Security Alert: Your account has been suspended"	HIGH
10	Attacker Identity in Message-ID	123456789.attacker@attacker-server.com	CRITICAL

Evidence — Google Admin Toolbox Messageheader Analysis:

[Screenshot: Google Admin Toolbox showing SPF: fail with IP Unknown, From: support@wellsfargo.com via PHPMailer 5.2, Delay table showing route from attacker-server.com to mail-protection-outlook.com]

How This Attack Works

The attacker forged the email's "From" field to display support@wellsfargo.com, making the message appear to come from Wells Fargo in the victim's inbox. However, the email actually originated from attacker-server.com — completely unrelated infrastructure. Standard SMTP does not verify the From field by default, which is why email authentication protocols (SPF, DKIM, DMARC) exist. In this case, the Google Admin Toolbox confirms SPF failed because Wells Fargo's DNS does not authorize the attacker's server to send mail on its behalf. Because DKIM and DMARC are also absent, the email was not automatically rejected — it reached the inbox looking legitimate. Had the victim replied, the response would have gone to the attacker's Reply-To address (update-services@fastmail.com), not to Wells Fargo.

RISK CLASSIFICATION: PHISHING — CRITICAL RISK | Domain Spoofing / Brand Impersonation

4. Email Risk Classification Framework

Use this framework to classify any incoming email. Train all employees to apply this three-tier system before acting on any email.

Level	Indicators	Recommended Action	Sample Verdict
SAFE	Known sender, verified domain, expected content, no urgency	Read normally. Verify via other channel if unexpected.	Newsletter from subscribed vendor
SUSPICIOUS	Unknown sender, unusual domain, unexpected attachment, mild urgency	Do NOT click. Report to IT. Call sender to verify.	Invoice PDF from unknown vendor
PHISHING	Fake domain, credential request, extreme urgency, malware link	Do NOT click or reply. Report immediately. Delete email.	All 3 samples above

5. Phishing Indicator Checklist

Apply this checklist to every suspicious email. If 3 or more indicators are present, classify as PHISHING.

Sender & Domain Red Flags

- **Fake lookalike domain:** amazon-support-center.com instead of amazon.com
- **Mismatched Reply-To:** Reply-To domain differs from From domain
- **Recently registered domain:** Checked via WHOIS — created days or weeks ago
- **Non-standard TLD:** .net, .org, .xyz used for company that should use .com

- **External domain for internal email:** IT using Gmail or .org domain

Content & Language Red Flags

- **Generic greeting:** Dear User / Dear Customer / Dear Employee
- **Urgency and deadlines:** 24 hours / 2 hours / immediately / right now
- **Fear and threats:** Permanent suspension / account disabled / legal action
- **Request for credentials:** Password / OTP / PIN requested via email
- **Grammar or spelling errors:** Professional organizations don't send typo-filled emails

Link & Attachment Red Flags

- **HTTP instead of HTTPS:** No SSL certificate on login or payment pages
- **URL doesn't match display text:** Button says 'Verify' but link goes elsewhere — hover first
- **Executable attachment:** .exe, .bat, .vbs files disguised as documents or invoices
- **Macro-enabled Office files:** .docm or .xlsm with 'Enable Macros' prompts
- **Password-protected ZIP:** Used to bypass antivirus scanning of malware inside

6. Prevention & Awareness Guidelines

5.1 The SLAM Method — Quick Check for Every Email

Letter	Stands For	What to Check Before Acting
S	Sender	Is the sender's email domain legitimate? Does it exactly match the real company's domain?
L	Links	Hover over every link BEFORE clicking. Does the URL match the expected destination?
A	Attachments	Were you expecting this file? Is it an unusual type (.exe, .zip, .docm)?
M	Message	Does the email create urgency? Does it ask for passwords, OTPs, or money?

5.2 Employee Do's and Don'ts

DO — Safe Practices	DON'T — Dangerous Behaviors
✓ Verify unexpected emails by calling the sender directly	X Click links in emails without hovering to check the URL first
✓ Check the full sender domain — not just the display name	X Open attachments from unknown or unexpected senders

DO — Safe Practices	DON'T — Dangerous Behaviors
✓ Enable Multi-Factor Authentication (MFA) on all accounts	X Enter credentials on any page reached through an email link
✓ Report suspicious emails to IT/Security immediately	X Forward suspicious emails to colleagues
✓ Access websites by typing URLs directly in your browser	X Share OTPs, passwords, or PINs with anyone via email
✓ Keep antivirus and software updated at all times	X Click Unsubscribe in suspected phishing emails
✓ Use a password manager — unique password for every site	X Assume an email is safe because it looks professional
✓ Attend cybersecurity awareness training regularly	X Reply to phishing emails — it confirms your email is active

5.3 If You Already Clicked a Phishing Link

Immediate Incident Response Steps

1. Disconnect from the internet immediately — disable Wi-Fi or unplug LAN cable to stop data exfiltration
2. Do NOT shut down the computer — this preserves forensic evidence for security investigation
3. Report to your IT Security team immediately with the original email and details of what was clicked
4. Change all passwords from a different, clean device — especially if you entered credentials
5. Enable MFA on all affected accounts immediately to block attackers even with stolen credentials
6. Monitor bank accounts, email sent items, and login history for any unauthorized activity

7. Technical Defenses for Organizations

Control	Purpose	How to Implement
SPF Record	Prevents unauthorized servers from sending email on behalf of your domain	Add TXT record to DNS listing your authorized mail server IPs
DKIM Signature	Cryptographically proves email was not tampered with in transit	Generate key pair; publish public key in DNS; sign outgoing mail
DMARC Policy	Enforces SPF/DKIM and sends failure reports to domain owner	Set p=quarantine or p=reject in DNS TXT record

Control	Purpose	How to Implement
Email Gateway Filtering	Scans all incoming emails for phishing URLs, malware, and spam patterns	Deploy Proofpoint, Mimecast, or Microsoft Defender for O365
Multi-Factor Authentication	Blocks attacker access even when credentials are stolen	Enforce MFA for all users via Azure AD, Okta, or Google Workspace
Security Awareness Training	Trains employees to recognize and report phishing attempts	Quarterly simulated phishing tests + training modules
Incident Response Plan	Ensures fast, coordinated action when a phishing attack succeeds	Define reporting chain, containment steps, and communication plan

8. Conclusion

Phishing remains the most prevalent and damaging initial attack vector in cybersecurity today. As demonstrated by the three samples analyzed in this report, attackers rely on psychological manipulation — fear, urgency, and authority — rather than technical exploits to compromise victims.

Key Takeaways

7. Human awareness is the single most effective phishing defense — technology alone cannot stop it
8. Always verify the sender's full domain — not just the display name shown in the email client
9. No legitimate organization ever requests your password, OTP, or PIN via email
10. Use the SLAM method (Sender, Links, Attachments, Message) to evaluate every suspicious email
11. Organizations must deploy SPF, DKIM, DMARC, and MFA as baseline email security controls
12. If you suspect phishing — report it immediately. Speed is critical in incident response